Employee Guide: Spot and Report Phishing

A one-page action guide for non-technical staff

1. Pause

Unexpected urgency is a warning. Do not click, reply, download, scan a QR code or call a number provided in the message.

2. Check the sender and destination

• Expand the sender details and read the complete address.

• Compare the domain with the organization’s known official domain.

• Hover or preview a link without opening it. Read the registrable domain immediately before the first single slash.

• Treat a mismatched Reply-To, shortened URL or unrelated domain as suspicious.

3. Recognize the pressure

Common tactics include account suspension, unusual sign-ins, unpaid invoices, delivery failures, prizes, executive authority, secrecy and short deadlines.

4. Verify independently

Open the official app or type a trusted bookmark yourself. Call a known number from the company website or internal directory—not one in the email.

5. Report

• Use the official Report Phishing button or approved security mailbox.

• Preserve the original message and headers when policy allows.

• Do not forward live links casually or share screenshots containing personal data.

• Delete only after reporting.

If you clicked or submitted information

Contact IT/security immediately. State what you clicked, downloaded or entered. Change the affected password through a known-clean official route, revoke active sessions if instructed, and report payment or personal-data exposure without delay. Do not hide the mistake—fast reporting limits damage.

Remember: SPF/DKIM/DMARC passing does not guarantee safety. An attacker can use a legitimate but compromised service. Judge identity, destination, request and context together.